Etude de conformité RGPD et sécurité

05/03/2026
INTRO BIG DATA

LUKAS B-LEGRET
YELDA ADOUANE

1. Analyse des risques sur la BDD initiale

Pourquoi le fait de stocker les emails en clair dans la table customer_transactions posait-il un problème majeur d'un point de vue de la sécurité et de la législation ?

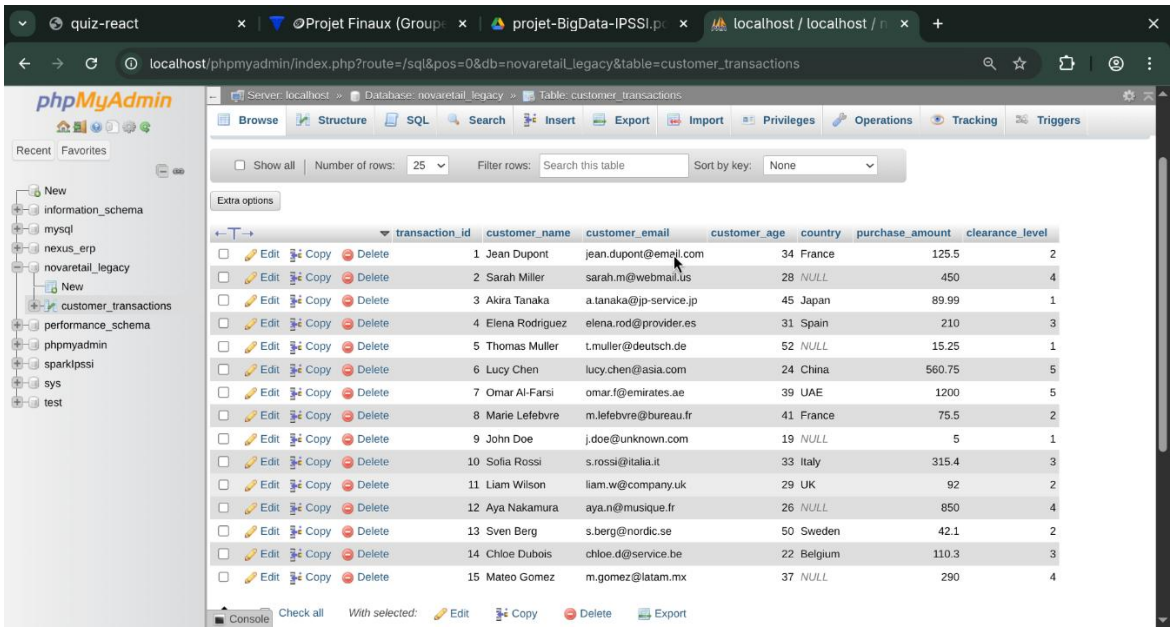

Table customer_transactions

1.1 Risques de sécurité !

a. <u>Exposition directe en cas de fuite</u>

Si la base est compromise (attaque, mauvaise configuration, accès non autorisé), les emails en clair peuvent être immédiatement exploités pour :

- du phishing ciblé
- des campagnes de spam
- des usurpations d'identité

b. <u>Absence de chiffrement ou de pseudonymisation</u>

Le RGPD recommande fortement de chiffrer ou pseudonymiser les données personnelles sensibles. Stocker les emails en clair signifie qu'aucune mesure technique de protection n'a été appliquée.

c. <u>Effet multiplicateur en cas de corrélation</u>

Combinés à d'autres champs comme le nom, l'âge ou le pays, les emails permettent de profiler les individus, ce qui aggrave les conséquences d'une fuite de données.

1.2 Problèmes de conformité au RGPD

a. Violation du principe de minimisation

Le RGPD impose de ne collecter que les données strictement nécessaires. Si l'email n'est pas indispensable à la transaction, sa présence est injustifiée.

b. Manque de mesures de sécurité appropriées

L'article 32 du RGPD exige que les responsables de traitement mettent en œuvre des mesures techniques et organisationnelles pour garantir la sécurité des données. Le stockage en clair est considéré comme une négligence.

c. Obligation d'information et de consentement

Les personnes concernées doivent être informées de la manière dont leurs données sont traitées. Si les emails sont stockés sans consentement explicite ou sans finalité claire, cela constitue une infraction.

2. Principes du RGPD appliqués

Expliquer en quoi votre pipeline ETL codé en Java répond au principe de "Minimisation des données".

Dans notre pipeline ETL codé en Java, nous avons pris la décision de supprimer purement et simplement la colonne customer_email lors de la phase de transformation (Map/Filter). Le principe de minimisation du RGPD stipule qu'une entreprise ne doit collecter et conserver que les données strictement nécessaires à la finalité du traitement. Notre nouveau Data Lake (fichiers distribués) est conçu pour de l'analyse statistique et de l'historisation des ventes (Big Data). Pour faire des statistiques de vente par pays ou par montant, l'adresse email de l'utilisateur n'apporte aucune valeur ajoutée ("Valeur" des 5V). En la supprimant du Dataset final, nous respectons parfaitement ce principe légal

B. Cas d'usage : Le Droit à l'Oubli d'un client espagnol

Le Droit à l'effacement est un pilier du RGPD. Si un client espagnol demande la suppression totale de ses données, la structure de notre Data Lake facilite grandement cette opération.

- **La solution technique :** Grâce à l'utilisation de la fonction .partitionBy("country") lors de l'archivage (Load), nos données exportées en JSON sont organisées dans des sous-dossiers spécifiques par pays.

- **Le processus :** Au lieu de devoir scanner l'intégralité d'un Data Lake massif (ce qui serait extrêmement coûteux en temps et en puissance de calcul), le Data Engineer ou le script automatisé va cibler uniquement le sous-dossier country=Spain (ou Espagne). Il suffira ensuite de parcourir les fichiers JSON de ce dossier précis pour retrouver l'identifiant du client (customer_name ou transaction_id) et purger ses informations, répondant ainsi rapidement à l'exigence légale.

3. Sécurité et Architecture

3.1 Mesures de sécurité pour protéger le dossier d'export final (Fichiers JSON) :

Pour protéger le Data Lake (les fichiers JSON) hébergé sur les serveurs de NovaRetail, nous recommandons les mesures suivantes :

Chiffrement au repos (Encryption at rest) : Les fichiers JSON doivent être stockés sur des volumes chiffrés pour empêcher toute lecture en cas de vol ou d'accès physique non autorisé aux serveurs.

Gestion stricte des identités et des accès (IAM / RBAC) : L'accès doit être limité par rôles : seuls les profils autorisés (Data Engineers, services internes) peuvent lire les fichiers bruts. Les autres équipes n'accèdent qu'à des données dérivées ou agrégées.

Journalisation des accès : Chaque consultation ou tentative d'accès doit être enregistrée afin de détecter les comportements anormaux et tracer l'origine d'une éventuelle fuite.

3.2 Complexité de la sécurité : Distribué vs Relationnel (SQL) :

Surface d'attaque élargie : Une base relationnelle est centralisée sur un serveur unique, alors qu'un cluster Big Data répartit les données sur de nombreux nœuds. Chaque nœud devient un point potentiel de vulnérabilité qu'il faut sécuriser individuellement.

Données en transit plus exposées : Dans un système distribué, les données circulent constamment entre les serveurs (shuffle, réplication). Ce trafic doit être chiffré pour éviter toute interception, un risque beaucoup moins présent dans une base SQL centralisée.

Multiplication des technologies à sécuriser : L'écosystème Big Data repose sur plusieurs outils (Hadoop, Spark, Kafka, etc.), chacun avec ses propres mécanismes de sécurité. Il faut harmoniser l'ensemble, ce qui augmente fortement la complexité globale.